TUGAS PRAKTIKUM INDIVIDU

Zero Trust Security

Keamanan Informasi (KP70065004) · Informatika Universitas Siliwangi

1. Tujuan

- Menerapkan prinsip *zero trust* (*never trust*, *always verify*; *least privilege*; *assume breach*) langsung di level aplikasi.
- Membangun API gateway sebagai Policy Enforcement Point (PEP) yang terpisah dari service, sesuai NIST SP 800-207.

2. Skenario

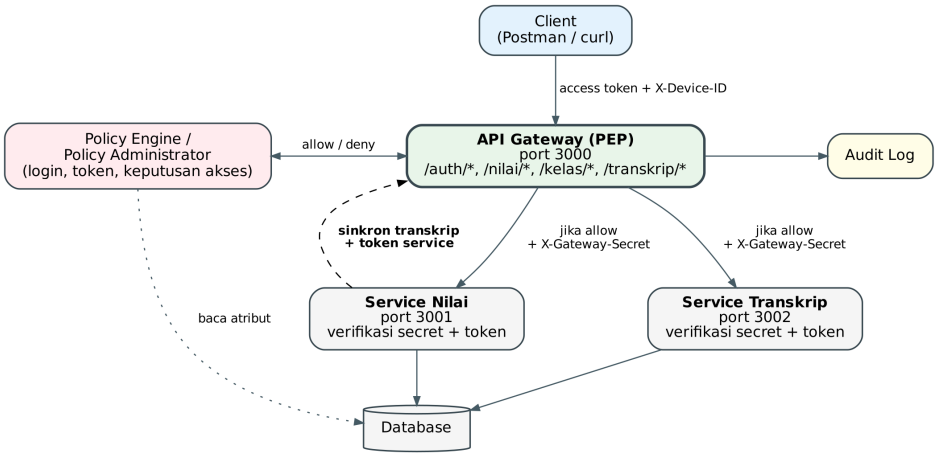
Program studi Informatika membutuhkan Sistem Nilai untuk mengelola nilai mata kuliah. Dosen menginput dan memfinalisasi nilai kelas yang diampunya. Setelah difinalisasi, nilai dikirim ke Service Transkrip agar masuk ke transkrip mahasiswa. Seluruh akses diperiksa oleh API gateway, termasuk panggilan antar-service.

Role	Hak akses
Mahasiswa	Melihat nilai dan transkrip miliknya sendiri
Dosen	Melihat, mengubah, dan memfinalisasi nilai pada kelas yang diampunya
Admin	Melihat transkrip seluruh mahasiswa

Tabel 1. Role dan hak akses

3. Arsitektur Sistem

Sistem yang dibangun wajib mengikuti arsitektur berikut.



Gambar 1. Arsitektur Sistem Nilai

Komponen	Peran (NIST SP 800-207)	Tanggung jawab
API Gateway (port 3000)	PEP	Satu-satunya pintu masuk. Memeriksa setiap request, meminta keputusan ke Policy Engine, mencatat audit log, lalu meneruskan request ke service.

Komponen	Peran (NIST SP 800-207)	Tanggung jawab
Policy Engine / Policy Administrator	PE / PA	Modul di dalam gateway. Menangani login, menerbitkan dan mencabut token, serta memutuskan allow/deny berdasarkan kebijakan pada Tabel 3 dan atribut dari database.
Service Nilai (port 3001)	Resource	Data nilai dan kelas. Memverifikasi gateway secret dan token. Saat finalisasi, memanggil Service Transkrip melalui gateway.
Service Transkrip (port 3002)	Resource	Data transkrip mahasiswa. Memverifikasi gateway secret dan token.
Database	Resource	Satu database bersama untuk kedua service.
Audit Log	Data source	Tabel di database atau file log yang ditulis oleh gateway.

Tabel 2. Komponen sistem

4. Kebutuhan Sistem

4.1 Autentikasi dan Token

- **Access token:** JWT berlaku 10 menit, minimal berisi `sub` dan `role`. Dikirim melalui header `Authorization: Bearer <token>`.
- **Refresh token:** berlaku 1 hari dan disimpan di database sehingga dapat dicabut. Logout mencabut refresh token.
- **Token service:** Service Nilai memperoleh token dari `POST /auth/service` menggunakan client ID dan secret. Token berlaku 5 menit dengan `role: service`.
- **Gateway secret:** gateway menambahkan header `X-Gateway-Secret` saat meneruskan request. Service menolak request tanpa header ini, sehingga service tidak dapat diakses langsung.
- **Verifikasi ulang di service:** selain memeriksa gateway secret, setiap service juga memverifikasi tanda tangan dan masa berlaku access token atau token service yang diteruskan gateway. Request tanpa token valid tetap ditolak walaupun membawa gateway secret.

4.2 Kebijakan Akses

Semua endpoint diakses melalui gateway. Selain endpoint /auth/*, setiap request dari user wajib membawa access token yang valid dan device terdaftar (4.3). Panggilan dari Service Nilai menggunakan token service. Kebijakan yang bergantung pada kepemilikan data (cth. kelas yang diampu dosen, NIM milik mahasiswa) tidak bisa diputuskan hanya dari isi token. Untuk itu, Policy Engine membaca data user, kelas, dan nilai dari database.

Endpoint	Ditangani oleh	Diizinkan	Kondisi
`POST /auth/login`	Gateway	Semua user	Kredensial valid dan device terdaftar
`POST /auth/refresh`, `/auth/logout`	Gateway	Semua user	Refresh token valid dan belum dicabut
`POST /auth/service`	Gateway	Service Nilai	Client ID dan secret valid
`GET /nilai`	Nilai	Mahasiswa, dosen	Mahasiswa: hanya nilai miliknya. Dosen: hanya kelas yang diampu
`PUT /nilai/:id`	Nilai	Dosen	Kelas yang diampu, nilai belum final, dan dalam jam akses

Endpoint	Ditangani oleh	Diizinkan	Kondisi
`POST /kelas/:id/finalisasi`	Nilai	Dosen	Kelas yang diampu dan dalam jam akses. Setelah itu Service Nilai memanggil sinkron transkrip
`GET /transkrip/:nim`	Transkrip	Mahasiswa, admin	Mahasiswa: hanya NIM sendiri. Admin: semua NIM
`POST /transkrip/sinkron`	Transkrip	Service Nilai	Hanya token service. Token user mana pun ditolak

Tabel 3. Kebijakan akses

4.3 Verifikasi Konteks

- **Device terdaftar:** setiap request dari user membawa header `X-Device-ID`. Request dari device yang tidak terdaftar untuk user tersebut ditolak.
- **Jam akses:** perubahan dan finalisasi nilai hanya diizinkan pukul 07.00–21.00. Rentang jam dibuat dapat diatur melalui konfigurasi agar mudah didemokan.

4.4 Audit Log

Gateway mencatat setiap keputusan akses: waktu, subjek (user atau service), endpoint, device, hasil (allow/deny), dan alasan.

5. Ketentuan Teknis

- **Framework dan bahasa bebas.** Penilaian berfokus pada mekanisme kontrol akses, bukan tampilan.
- **Berjalan di satu komputer,** langsung atau menggunakan Docker/Docker Compose. Frontend tidak wajib; pengujian menggunakan Postman atau curl.
- **Data awal (seed):** minimal 1 admin, 2 dosen, 3 mahasiswa, dan 2 kelas yang diampu dosen berbeda. Setiap user memiliki 1 device terdaftar.

Rekomendasi tool stack:

Komponen	Tool
API Gateway	Node.js + Express dengan http-proxy-middleware untuk meneruskan request
Service Nilai dan Transkrip	Node.js + Express, masing-masing satu aplikasi
Token	jsonwebtoken (JWT), cth. expiresIn: '10m'
Policy Engine	Modul policy.js di gateway yang mengembalikan allow/deny beserta alasan
Panggilan antar-service	fetch (bawaan Node.js 18+) ke gateway dengan header Authorization
Database	SQLite (tanpa server database, cth. paket better-sqlite3) atau MySQL/MariaDB melalui Laragon/XAMPP

6. Luaran

1. Repository kode beserta README berisi cara menjalankan, daftar akun, dan device ID data awal.
2. Video demo 6–9 menit yang menjelaskan bagaimana setiap kebutuhan pada bagian 4 diterapkan dengan menunjukkan bagian kode yang menanganinya.

Selamat mengerjakan!